

Third-Party Security Policy

ISMS Governance Policy | Version 1.0 | Approved

Document Owner	Information Security / GRC
Status	Approved 2026-09-23
Review Frequency	At least annually and upon significant change
Framework Alignment	ISO/IEC 27001:2022
Classification	Internal Use

1. Purpose

Establish a risk-based approach for evaluating and managing information security risks arising from third-party relationships.

2. Scope

Applies to third parties providing technology, cloud, software, data processing, infrastructure, professional, or other services that may affect Axiom AI information security.

3. Risk Classification

- Third parties shall be assessed using information sensitivity, system access, business criticality, service dependency, and potential impact.
- Critical and higher-risk suppliers shall receive enhanced due diligence.
- Third-party risk assessments shall be documented.

4. Security Requirements

- Relevant contracts should include confidentiality, security, incident notification, data protection, and service requirements.
- Suppliers with privileged or sensitive access shall receive appropriate access controls.
- Critical supplier security posture shall be reviewed periodically or after significant changes.
- Security findings shall be tracked and addressed according to risk.

5. Onboarding and Offboarding

Third-party access shall be authorized, limited to business need, monitored where appropriate, and removed when no longer required.

6. Exceptions and Risk Acceptance

Supplier exceptions require documented justification, compensating measures where available, and appropriate risk acceptance.

7. Review and Approval

This policy shall be reviewed at least annually and when significant changes occur to Axiom AI's business, technology, threats, legal or contractual obligations, or information security risk profile.

8. Portfolio Disclaimer

Axiom AI Technologies is a fictional organization created for portfolio demonstration purposes. This policy is inspired by and based on real professional cybersecurity, GRC, and ISO/IEC 27001 practices and is not an actual organizational policy.